

Manual 17 — Implementación Controlada del NIST Privacy Framework

Edición controlada es-419

****Orden de la serie:**** 17

****Línea base estable:**** NIST Privacy Framework 1.0

****Identidad de origen congelada:**** `80d8569aeeb57d209293f8fe1423be43efa36cdb`

****Decisión sobre el estado de la fuente:**** PF 1.1 continúa como Borrador Público Inicial / publicación final futura; el material del borrador 1.1 se usa únicamente como inteligencia de cambio no normativa.

****Estado de publicación:**** fuente controlada localizada; aún no renderizada, vinculada por hash, almacenada de forma durable ni publicada.

Uso y límites

Esta es una guía de implementación independiente. No reproduce texto protegido de terceros, no crea derechos de certificación y no convierte la orientación voluntaria de NIST en requisitos legales. Cada organización debe determinar por separado las leyes de privacidad, contratos, requisitos regulatorios, obligaciones sectoriales y deberes jurisdiccionales aplicables.

El modelo de implementación usa el NIST Privacy Framework 1.0 publicado como línea base determinista y organiza la gobernanza alrededor de las funciones Identify-P, Govern-P, Control-P, Communicate-P y Protect-P, utilizando lenguaje de implementación original.

Modelo de evidencia controlada

Cada control de privacidad implementado debe poder trazarse mediante: autoridad o justificación; responsable; procedimiento repetible; activador/frecuencia; objeto de evidencia; ubicación de la evidencia; método de revisión/prueba; ruta de excepción/remediación; y activador de reevaluación.

Rutas de implementación:

- ****Esencial:**** gobernanza y evidencia mínimas y repetibles.
- ****Estructurada:**** modelo operativo multifuncional documentado con métricas, pruebas y escalamiento.
- ****Avanzada:**** evidencia automatizada, análisis cuantitativo, monitoreo continuo y aseguramiento integrado.

Capítulo 1 — Propósito del Programa de Privacidad y Modelo Operativo

Definir carta del programa, alcance, derechos de decisión, calendario operativo anual, umbrales de escalamiento e informes de gestión. Responsable: líder ejecutivo de privacidad.

Evidencia: carta aprobada, RACI, calendario, registro de decisiones y aprobaciones de gobernanza. Probar anualmente que todas las actividades requeridas tengan responsable, periodicidad, repositorio y ruta de escalamiento. Reevaluar después de cambios regulatorios, organizacionales, tecnológicos, de producto o incidentes relevantes.

Capítulo 2 — Contexto Organizacional y Partes Interesadas

Identificar líneas de negocio, jurisdicciones, personas, reguladores, clientes, población laboral, proveedores, objetivos estratégicos y dependencias que configuran el riesgo de privacidad. Responsable: oficina de privacidad con legal y riesgo empresarial. Evidencia: registro de contexto, inventario de partes interesadas, matriz jurisdiccional y supuestos de riesgo. Revisar anualmente y después de entrada a mercados, adquisiciones, reestructuración, consultas regulatorias o cambios contractuales importantes.

Capítulo 3 — Alcance y Límites

Definir entidades, sistemas, datos, productos, ubicaciones, procesos y terceros cubiertos; documentar exclusiones y dependencias. Responsable: líder de privacidad con arquitectura y responsables de negocio. Evidencia: declaración de alcance, diagramas de límites, registro de exclusiones y mapa de dependencias. Conciliar el alcance con inventarios de activos, proveedores, aplicaciones y tratamientos.

Capítulo 4 — Gobernanza y Responsabilidad del Liderazgo

Establecer política de privacidad, apetito de riesgo, foros de gobernanza, umbrales de reporte, decisiones de recursos, escalamiento y revisión gerencial. Responsable: órgano ejecutivo de gobernanza. Evidencia: estatuto del comité, actas, decisiones, informes de riesgo y aprobaciones de recursos. Verificar que riesgos significativos y acciones vencidas lleguen a la dirección con disposición documentada.

Capítulo 5 — Roles, Responsabilidades y Segregación

Mantener RACI y autoridades delegadas para privacidad, legal, seguridad, ingeniería, producto, gobierno de datos, RR. HH., compras, respuesta a incidentes, auditoría y ejecutivos. Evidencia: declaraciones de responsabilidad del puesto, aprobaciones delegadas y reglas de segregación. Probar decisiones muestradas para confirmar aprobación autorizada y revisión independiente cuando corresponda.

Capítulo 6 — Inventario de Tratamientos y Mapeo de Datos

Mantener registros actuales de recopilación, generación, uso, intercambio, almacenamiento, transformación, archivo y eliminación de datos personales. Registrar categorías, personas,

fines, fuentes, destinatarios, ubicaciones, retención, justificación, clasificación y relaciones con encargados. Evidencia: inventario de tratamientos, flujos de datos, atestaciones de responsables e informes de conciliación. Conciliar continuamente con revisión formal anual.

Capítulo 7 — Metodología de Evaluación del Riesgo de Privacidad

Definir escenarios de riesgo, personas afectadas, acciones problemáticas sobre datos, dimensiones de consecuencia, supuestos de probabilidad, fortaleza de controles, riesgo residual, incertidumbre, autoridad de aceptación y períodos de reevaluación. Evidencia: metodología aprobada, evaluaciones, supuestos y decisiones de riesgo residual. Reejecutar muestras para validar consistencia de puntuación y calidad de evidencia.

Capítulo 8 — Evaluación de Impacto y Revisión de Alto Riesgo

Examinar tratamientos nuevos o modificados para revisión reforzada; documentar propósito, necesidad, flujos, poblaciones, escenarios de riesgo, salvaguardas, alternativas, riesgo residual, aprobaciones y condiciones de monitoreo. Evidencia: registro de cribado, evaluación de impacto, aprobación, condiciones y prueba de implementación. El tratamiento de alto riesgo no aprobado se escala para restricción, rediseño o decisión formal de riesgo.

Capítulo 9 — Políticas, Estándares y Procedimientos

Mantener una jerarquía controlada que vincule política de privacidad con estándares, procedimientos, responsables, aprobaciones, ciclos de revisión y evidencia. Evidencia: biblioteca documental controlada, historial de versiones, aprobaciones, constancias y archivo de retiro. Probar requisitos de política muestreados contra procedimientos operativos y evidencia.

Capítulo 10 — Privacidad desde el Diseño e Ingeniería

Integrar puntos de control de privacidad en arquitectura, producto, software, datos y ciclos de cambio. Evaluar minimización, separación, acceso, retención, transparencia, controles de usuario, telemetría y capacidad de prueba. Evidencia: registro de diseño de privacidad, revisión de arquitectura, análisis de riesgo, decisiones, pruebas y condiciones de aprobación. Reevaluar ante cambios materiales de funcionalidad, integración, modelo o arquitectura.

Capítulo 11 — Especificación del Propósito y Limitación de Uso

Registrar fines de tratamiento aprobados y gobernar usos secundarios materiales. Evidencia: registro de propósitos, aprobaciones de casos de uso, evaluaciones de cambio, registro de decisiones y vínculo con avisos. Comparar uso real de sistemas y analítica con

finés aprobados. Los usos no respaldados requieren suspensión, reducción, eliminación o reevaluación.

Capítulo 12 — Minimización de Datos y Controles de Recopilación

Exigir justificación de atributos recopilados, cuestionar campos opcionales, eliminar copias redundantes y usar agregación o desidentificación cuando proceda. Evidencia: justificación de elementos de datos, revisiones de esquema, formularios de recopilación y registros de depuración. Probar sistemas muestreados para detectar campos sin propósito actual o justificación de retención.

Capítulo 13 — Consentimiento, Preferencias y Elección Individual

Cuando se usen mecanismos de consentimiento o preferencia, definir presentación, captura, prueba, retiro, propagación y manejo de excepciones. Evidencia: diseño de consentimiento, registros de preferencias, versiones de lenguaje, registros de propagación y pruebas de retiro. Ejecutar pruebas de extremo a extremo para confirmar que las preferencias modificadas llegan a sistemas posteriores dentro de los niveles de servicio definidos.

Capítulo 14 — Transparencia y Comunicaciones de Privacidad

Mantener avisos de privacidad y comunicaciones internas precisas y apropiadas para la audiencia, alineadas con el tratamiento real. Evidencia: inventario de avisos, mapeo tratamiento-aviso, aprobaciones, historial de versiones, prueba de publicación y revisión de accesibilidad/legibilidad. Corregir rápidamente inexactitudes materiales y evaluar personas y obligaciones afectadas.

Capítulo 15 — Operación de Solicitudes de las Personas

Operar flujos consistentes de recepción, verificación de identidad, enrutamiento, búsqueda, revisión, respuesta, excepción y evidencia para solicitudes de privacidad cuando sean legalmente exigibles o voluntariamente ofrecidas. Evidencia: tickets, registro de verificación, evidencia de búsqueda, paquete de respuesta, aprobación de excepción y métricas SLA. Probar solicitudes muestreadas por integridad, autorización, oportunidad y ejecución posterior.

Capítulo 16 — Calidad y Exactitud de Datos

Definir dónde la exactitud afecta materialmente a personas, decisiones, servicios u obligaciones; establecer procesos de corrección y propagación. Evidencia: reglas de calidad, registros de validación, correcciones y mapeos de fuente autorizada. Revisar

inexactitudes recurrentes y causas raíz; reevaluar cuando se introduzcan nuevos usos decisorios o integraciones de datos.

Capítulo 17 — Retención, Archivo y Eliminación

Mantener calendarios de retención vinculados a justificación documentada; implementar archivo y eliminación en producción, respaldo, analítica y terceros cuando sea viable. Evidencia: calendario de retención, configuración de sistemas, registros de eliminación, excepciones y retenciones legales. Probar almacenes de datos muestreados contra períodos aprobados.

Capítulo 18 — Identidad, Acceso y Manejo Privilegiado

Aplicar acceso basado en roles, mínimo privilegio, autenticación, controles de acceso privilegiado, revisión periódica y revocación oportuna a sistemas con datos personales. Evidencia: matrices de acceso, aprobaciones, registros, recertificaciones y sesiones privilegiadas. Probar muestras de altas/cambios/bajas y acceso privilegiado; remediar acceso excesivo.

Capítulo 19 — Coordinación entre Seguridad y Privacidad

Integrar requisitos de privacidad con riesgo de seguridad de la información, vulnerabilidades, registros, monitoreo, cifrado, respuesta a incidentes e ingeniería segura. Evidencia: mapeos conjuntos de controles, registros de riesgo, arquitectura de seguridad, resultados de monitoreo y tickets de remediación. Verificar que los controles de seguridad atiendan escenarios de riesgo de privacidad y no asumir que la seguridad por sí sola resuelve el riesgo de privacidad.

Capítulo 20 — Gobernanza de Terceros y Encargados

Evaluar proveedores y socios antes de la contratación y durante toda la relación. Registrar propósito, alcance de datos, jurisdicción, controles de seguridad/privacidad, obligaciones contractuales, subencargados, incidentes, retención, devolución/eliminación y salida. Evidencia: debida diligencia, contratos, evaluaciones de riesgo, monitoreo, remediación y prueba de desvinculación.

Capítulo 21 — Nube y Responsabilidad Compartida

Documentar responsabilidades de privacidad entre cliente, proveedor cloud, SaaS y subencargados. Mapear ubicaciones de datos, acceso administrativo, responsabilidad de cifrado/claves, registros, retención, eliminación, notificación de incidentes y propiedad de configuración. Evidencia: matriz de responsabilidad compartida, diagramas de arquitectura, atestaciones del proveedor y revisiones de configuración.

Capítulo 22 — Movimiento Transfronterizo y Jurisdiccional de Datos

Mantener visibilidad de almacenamiento, acceso remoto, transferencias, divulgaciones ulteriores y restricciones jurisdiccionales relevantes. Responsable: privacidad/legal con arquitectura y compras. Evidencia: inventario de transferencias, referencias de evaluación legal, mecanismos contractuales cuando apliquen, registros de ubicación y decisiones de aprobación. Reevaluar ante cambios de proveedor, ubicación, ley o modelo de acceso.

Capítulo 23 — Interfaz de Incidentes y Brechas

Integrar privacidad en triage, preservación de evidencia, análisis de impacto, evaluación legal/regulatoria, evaluación del impacto a personas, decisiones de notificación y remediación posterior. Evidencia: registros de incidentes, decisiones, cronologías, evaluaciones de notificación, análisis de causa raíz y acciones correctivas. Ejecutar ejercicios de mesa al menos anualmente.

Capítulo 24 — Monitoreo y Efectividad de Controles

Definir indicadores de operación de controles, tendencias de riesgo, desempeño de solicitudes, incidentes, quejas, excepciones, hallazgos de terceros, inventarios obsoletos y antigüedad de remediación. Evidencia: tableros, informes de excepciones, análisis de tendencias y registros de acciones. Establecer umbrales que activen escalamiento y reevaluación.

Capítulo 25 — Métricas de Privacidad e Informes de Gestión

Usar métricas que apoyen decisiones, no conteos sin utilidad. Definir responsable, fórmula, sistema fuente, frecuencia, umbral, objetivo, audiencia y acción para cada métrica. Evidencia: diccionario de métricas, tableros, conciliaciones de fuentes e informes gerenciales. Validar periódicamente calidad de datos y capacidad de las métricas para impulsar decisiones.

Capítulo 26 — Revisión Interna y Aseguramiento

Planificar revisiones basadas en riesgo sobre gobernanza, inventarios, evaluaciones, ingeniería, solicitudes, retención, proveedores, incidentes y calidad de evidencia. Mantener independencia del revisor proporcional al riesgo. Evidencia: plan de revisión, papeles de trabajo, muestras, hallazgos, respuestas de gestión y validación de cierre. Repetir pruebas después de remediación material.

Capítulo 27 — Acción Correctiva y Remediación

Registrar hallazgos y fallas con severidad, causa raíz, responsable, fecha objetivo, salvaguardas provisionales, evidencia de corrección y validación de cierre. Evidencia:

registro de remediación, tickets, resultados de validación y aceptación de riesgo si se extiende el plazo. Escalar elementos de alto riesgo vencidos según umbrales de gobernanza.

Capítulo 28 — Excepciones y Aceptación de Riesgo

Exigir justificación documentada, alcance, riesgo, medidas compensatorias, responsable, aprobador, vencimiento y reevaluación. Evidencia: registro de excepciones, aprobaciones, pruebas de controles compensatorios y alertas de vencimiento. Prohibir excepciones indefinidas o renovadas automáticamente sin reevaluación explícita.

Capítulo 29 — Capacitación, Concientización y Competencia por Rol

Definir concientización básica más capacitación específica para privacidad, legal, ingeniería, producto, RR. HH., compras, seguridad, soporte y ejecutivos. Evidencia: currículos, registros de finalización, evaluaciones, mapeo por rol y remediación por fallas. Revisar contenido después de cambios materiales de política, regulación, tecnología o incidentes.

Capítulo 30 — Arquitectura de Evidencia, Rutas de Madurez y Plan de Implementación

Mantener un repositorio gobernado y un modelo de trazabilidad que conecte decisiones de riesgo, controles, procedimientos, sistemas, responsables, pruebas, hallazgos y remediación. Usar rutas Esencial, Estructurada y Avanzada para secuenciar implementación según riesgo y capacidad. Evidencia: matriz control/evidencia, hoja de ruta, evaluación de madurez, mapa de dependencias y aprobaciones de gestión.

Capítulo 31 — Activadores de Cambio y Reevaluación del Framework

Definir activadores de reevaluación: cambios legales/regulatorios, actualizaciones NIST, incidentes, adquisiciones, nuevas jurisdicciones, nuevos usos de IA/analítica, cambios importantes de proveedor, modelos de negocio y fallas repetidas. Evidencia: registro de vigilancia de cambios, verificación de fuentes, análisis de impacto y decisiones controladas. La publicación final de PF 1.1 requiere conciliación explícita antes de cualquier congelamiento que declare alineación con esa versión.

Capítulo 32 — Publicación, Localización, Procedencia y Reevaluación

Congelar la fuente inglesa controlada solo después de que QA de fuente/copyright/semántica confirme el alcance PF 1.0 y el tratamiento no normativo del borrador PF 1.1. Derivar es-419 y pt-BR únicamente de esa identidad exacta. Exigir paridad estructural y semántica trilingüe, generación DOCX/PDF, QA de renderizado y accesibilidad,

vinculación SHA-256, manifiesto de procedencia, controles de seguridad de workflows, almacenamiento durable en main, QA exacta de head, verificación del orden del predecesor y conciliación final de catálogo/registro antes de publicar.

Lista final de aceptación de fuente controlada

Antes de la publicación verificar:

- presencia y orden de los 32 capítulos;
- PF 1.0 como línea base estable explícita;
- ausencia de representación del borrador PF 1.1 como final o vinculante;
- preservación del carácter voluntario del framework de NIST;
- diferenciación entre obligaciones legales y orientación del framework;
- conceptos de operación responsable, evidencia, revisión/prueba, remediación y reevaluación en cada capítulo;
- ausencia de reproducción de texto protegido de terceros;
- identidad de origen congelada correcta;
- estado de publicación bloqueado hasta completar todas las puertas artifact-first.